SIGED — Rapports de sprints

Du cadrage (sprint 0) à la recette (sprint 7)

Kombila N'Sougan Edere Levy — Cycle ingénieur SI, IAI Gabon

Octobre 2026

Sommaire

Sprint 0 — Cadrage, architecture et socle technique

Période : semaines 1 et 2 · **Objectif** : transformer le cahier des charges en backlog priorisé, arrêter l'architecture et livrer un squelette exécutable.

1. Organisation retenue

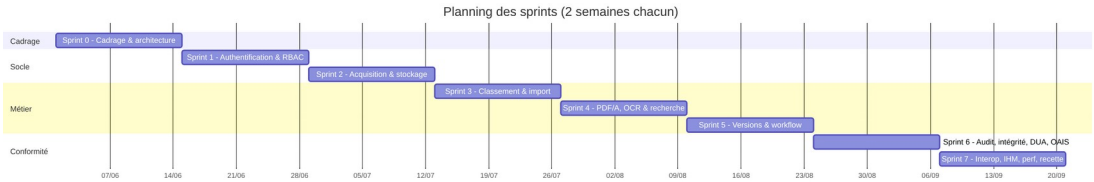
- Méthode **Scrum** : sprints de 2 semaines, revue et rétrospective en fin de sprint, backlog estimé en points (suite de Fibonacci).
- **Définition de « terminé »** : code relu, tests automatisés verts sur SQLite **et** PostgreSQL, exigence tracée dans la matrice de conformité, documentation (rapport de sprint) à jour.
- Outils : Git + GitHub Actions (intégration continue), Docker Compose (environnements identiques du poste du développeur à la production).

2. Découpage du cahier des charges en épopées

Épopée	Exigences	Sprint prévu
E1 — Identité, rôles, traçabilité de base	EX-03, EX-15, EX-19 (socle)	1
E2 — Acquisition et stockage sécurisé	EX-01, EX-05 (manuel), EX-07, EX-13, EX-14, EX-16 (repos)	2
E3 — Plan de classement et captures automatiques	EX-05 (lot, dossier, API), EX-08, EX-04 (messagerie)	3
E4 — Pérennisation et recherche	EX-02, EX-06, EX-09	4
E5 — Consultation, versions, validation	EX-10, EX-11, EX-12	5
E6 — Conformité archivistique	EX-17, EX-18, EX-19, EX-14 (contrôle)	6
E7 — Interopérabilité, IHM, performance, recette	EX-04, EX-16 (transit), EX-20	7

3. Livrables du sprint

- Cahier d'architecture v0.1 : choix FastAPI / PostgreSQL / MinIO / OCRmyPDF (ADR-01 à ADR-06).
- Modèle de données initial (11 tables), plan de classement de démonstration (4 séries, 7 rubriques).
- Squelette : `app/core` (configuration, base, sécurité), `docker-compose.yml`, `Makefile`, pipeline CI.
- Planning prévisionnel :



Planning

4. Risques identifiés

Risque	Probabilité	Impact	Parade
Outils OCR/PDF/A absents ou mal configurés sur le serveur cible	Moyenne	Fort	Image Docker contenant toute la chaîne ; dégradation gracieuse (statut `PARTIAL`)
Performance de la recherche sur gros volumes	Moyenne	Moyen	Index GIN dès la V1, test de charge automatisé, service de recherche isolé (OpenSearch possible)
Perte de la clé de chiffrement	Faible	Critique	Clé obligatoire en production, procédure de séquestre documentée
Écart entre l'élimination automatique et la pratique archivistique	Moyenne	Fort	Bordereau + visa de l'archiviste par défaut, mode automatique en option

5. Rétrospective

- **Positif** : la traçabilité exigence → épopée → test donne une vision claire de l'avancement.
- **À améliorer** : prévoir dès le départ un jeu de données de démonstration réaliste (fait au sprint 7, à anticiper).

Sprint 1 — Authentification, RBAC et socle d'audit

Période : semaines 3 et 4 · **Exigences** : EX-03, EX-15, EX-19 (socle) **Vélocité** : 21 points engagés / 21 livrés

1. Objectif du sprint

Aucun document ne doit être accessible sans identification, chaque action doit être autorisée selon le rôle, et toute connexion doit laisser une trace.

2. Récits utilisateurs

ID	En tant que…	je veux…	Points	Statut
US-1.1	utilisateur	me connecter avec identifiant et mot de passe	3	✔️
US-1.2	RSSI	que les comptes soient verrouillés après 5 échecs	2	✔️
US-1.3	administrateur	créer, modifier, désactiver des comptes et leur attribuer un rôle	3	✔️
US-1.4	RSSI	imposer une politique de mot de passe	1	✔️
US-1.5	administrateur	disposer de 5 rôles avec des permissions fines	5	✔️
US-1.6	ERP / SIRH	m'authentifier par clé d'API révocable	3	✔️
US-1.7	auditeur	voir les connexions réussies et échouées dans un journal	4	✔️

3. Réalisation

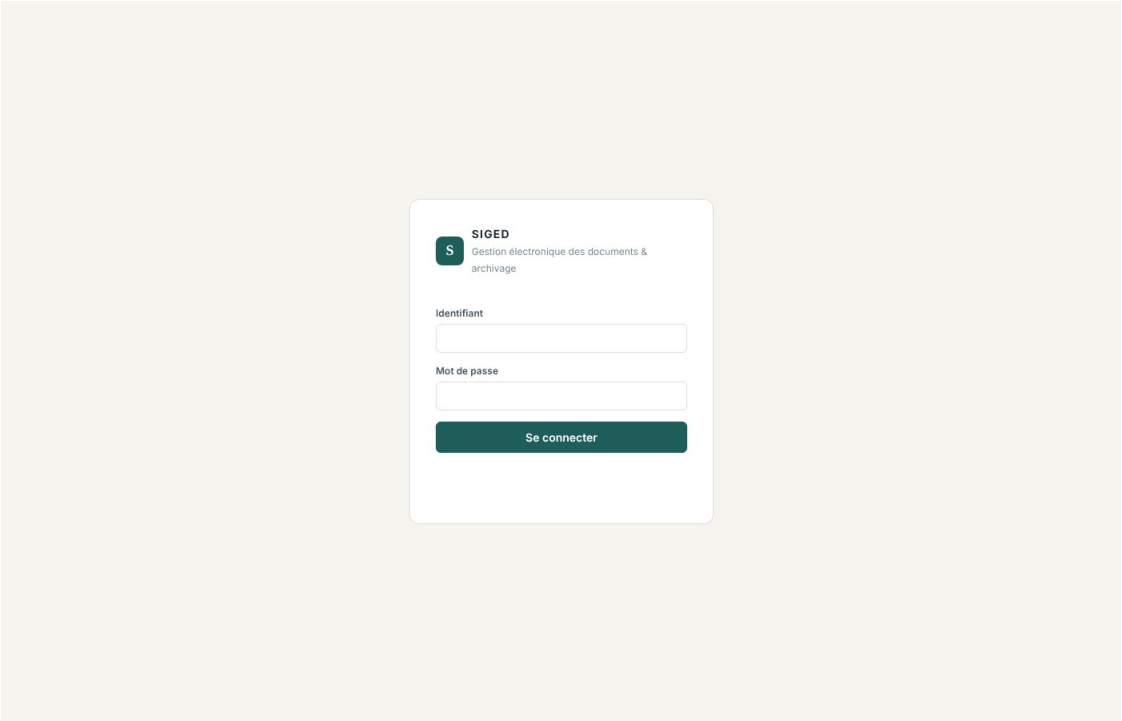
- **Mots de passe** : bcrypt (coût 12) ; politique 10 caractères, 3 classes sur 4.
- **Jetons JWT** de 30 min ; le compte est relu à chaque requête (désactivation immédiate).
- **RBAC** : 10 permissions, 5 rôles (`admin`, `archiviste`, `validateur`, `contributeur`, `lecteur`), vérifiées par la dépendance `require(...)` sur chaque route.
- **Clés d'API** : `sged_` + 256 bits aléatoires, affichées une seule fois, stockées hachées (SHA-256), rôle `admin` interdit.
- **Journal d'audit** : premières actions tracées (`LOGIN`, `LOGIN_FAILED`, `LOGIN_LOCKED`, `USER_CREATE`, `USER_UPDATE`) avec IP et agent utilisateur.
- Rôles et administrateur initial créés automatiquement au premier démarrage.

4. Tests (13 tests — `tests/test_sprint1_auth_rbac.py`)

Connexion valide et invalide · verrouillage après 5 échecs (423 même avec le bon mot de passe) · rejet sans jeton ou avec un jeton forgé · politique de mot de passe · lecteur ne peut pas déposer (403) · contributeur ne peut pas gérer les comptes ni lire l'audit · compte désactivé refusé · cycle complet d'une clé d'API ERP (création, dépôt, révocation → 401) · clé d'API admin refusée · traces de connexion présentes · liste des rôles.

Résultat : 13/13 ✔️

5. Démonstration



Connexion

6. Rétrospective

- **Positif** : centraliser la vérification des droits dans une dépendance unique évite les oublis route par route.
- **Difficulté** : le validateur d'e-mails refuse les domaines réservés (`.local`) ; les comptes de démonstration utilisent un domaine réel (`.ga`).
- **Action** : ajouter dès le sprint 2 l'enregistrement de l'acteur sur toutes les opérations documentaires.

Sprint 2 — Acquisition, empreinte SHA-256 et stockage hybride chiffré

Période : semaines 5 et 6 · **Exigences** : EX-01, EX-05 (manuel), EX-07, EX-13, EX-14, EX-16 (au repos) **Vélocité** : 26 points engagés / 26 livrés

1. Objectif du sprint

Déposer un document avec sa fiche de métadonnées obligatoire, prouver son intégrité dès la réception et le stocker chiffré, séparément de la base.

2. Récits utilisateurs

ID	Récit	Points	Statut
US-2.1	En tant que contributeur, je téléverse un fichier avec sa fiche (titre, auteur, date, type, mots-clés,	5	✔️

ID	Récit	Points	Statut
	DUA)		
US-2.2	En tant qu'archiviste, je veux qu'aucun document ne puisse être déposé sans fiche complète	2	✔️
US-2.3	En tant qu'auditeur, je veux l'empreinte SHA-256 de chaque fichier calculée au dépôt	3	✔️
US-2.4	En tant que RSSI, je veux les fichiers chiffrés en AES-256 et hors de la base	8	✔️
US-2.5	En tant que gestionnaire, je veux être averti si le fichier existe déjà (doublon)	3	✔️
US-2.6	En tant que métier, je veux ajouter des métadonnées libres (n° facture, matricule)	3	✔️
US-2.7	En tant qu'archiviste, je veux une cote lisible unique (DOC-AAAA-NNNNNN)	2	✔️

3. Réalisation

- **Réception en flux** : lecture par blocs de 1 Mo, empreinte SHA-256 calculée à la volée (aucune relecture), taille maximale configurable (200 Mo), fichier vide refusé.
- **Détection du type** par signature binaire (`%PDF`, PNG, JPEG, TIFF) : un PDF nommé `image.png` est bien reconnu comme PDF.
- **Stockage hybride** : interface `StorageBackend` avec deux implémentations (`LocalBackend`, `S3Backend` pour MinIO/S3) ; la base ne contient que la clé `originals/{document}/{version}`.
- **Chiffrement** : façade `EncryptedStorage` en AES-256-GCM par blocs, nonce unique par bloc, données associées anti-troncature ; écriture atomique (fichier temporaire + renommage).
- **Doublons** : refus 409 avec la cote du document existant, forçage possible (`allow_duplicate=true`).
- **Métadonnées** : validation Pydantic ; DUA et sort final héritables de la rubrique de classement, sinon dépôt refusé.
- **Transaction unique** : fiche + version 1.0 + entrée d'audit `DOCUMENT_CREATE` (avec empreinte et taille).

4. Tests (10 tests — `tests/test_sprint2_acquisition.py`)

Création v1.0 avec empreinte et date de fin de DUA exactes · chacun des champs obligatoires manquant → 422 · mots-clés vides → 422 · héritage de la DUA depuis la rubrique `RH.02` · refus sans DUA ni rubrique · doublon refusé puis forcé · **aucune donnée en clair sur le disque** (recherche d'une chaîne secrète dans les fichiers stockés) · base sans binaire · métadonnées dynamiques · aller-retour de chiffrement sur 3 Mo + détection d'un octet altéré + détection d'une troncature · détection MIME malgré une extension mensongère.

Résultat : 10/10 ✔️

5. Rétrospective

- **Positif** : le chiffrement par blocs permet de déchiffrer en flux (aperçu, téléchargement) sans charger le fichier en mémoire.
- **Point d'attention** : la clé AES devient un actif critique → démarrage refusé en production sans clé explicite ; procédure de séquestre ajoutée au cahier d'architecture.

Sprint 3 — Plan de classement, classement automatique et captures

Période : semaines 7 et 8 · **Exigences** : EX-05 (lot, dossier partagé, API), EX-08, EX-04 (messagerie entrante) **Vélocité** : 29 points engagés / 29 livrés

1. Objectif du sprint

Organiser les documents selon une arborescence métier normée et alimenter la GED sans saisie manuelle : lots, dossier partagé, messagerie.

2. Récits utilisateurs

ID	Récit	Points	Statut
US-3.1	En tant qu'archiviste, je gère le plan de classement (rubriques, DUA et sort final par défaut)	5	✔️
US-3.2	En tant que contributeur, mes documents sont classés automatiquement (type, mots-clés)	5	✔️
US-3.3	En tant que contributeur, je peux imposer la rubrique manuellement	1	✔️
US-3.4	En tant que service scanné, j'importe un lot de fichiers ou un ZIP avec manifeste	8	✔️
US-3.5	En tant qu'opérateur, je dépose des fichiers dans un dossier partagé capté automatiquement	5	✔️
US-3.6	En tant que secrétariat, les pièces jointes reçues par e-mail deviennent des documents	5	✔️

3. Réalisation

- **Plan de classement** arborescent (`ADM`, `RH`, `FIN`, `JUR` et 7 rubriques) avec DUA et sort final par défaut ; contrôle des cycles ; suppression refusée si la rubrique contient des sous-rubriques ou des documents.
- **Classement automatique** explicable : type de document = 10 pts, mot-clé de règle trouvé dans les mots-clés ou le titre = 3 pts, dans le texte OCR = 1 pt ; normalisation sans accents ni casse. Second passage après OCR si le document n'a pas été classé au dépôt. Endpoint `POST /api/classification/suggest` pour l'aide à la saisie.
- **Import par lot** : plusieurs fichiers avec métadonnées communes, ou ZIP + `manifest.csv` (séparateur `;` ou `,`) ; réponse 207 détaillant réussites et erreurs ligne par ligne.

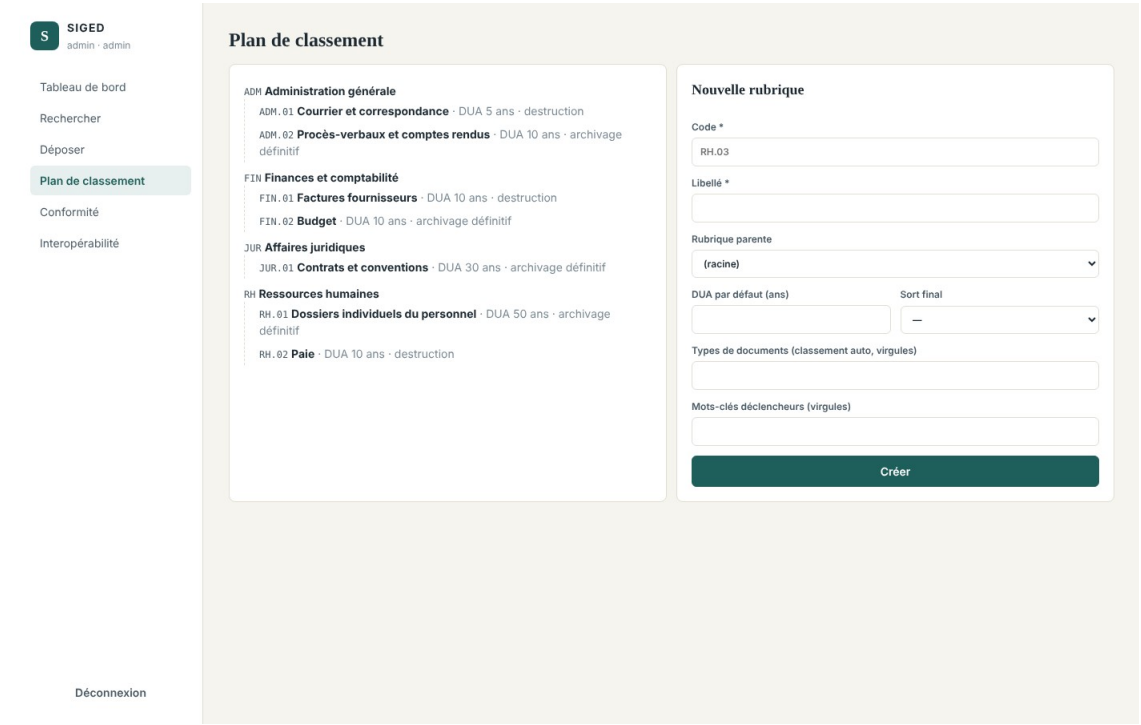
- **Dossier partagé (hot folder)** : fiche `.json` optionnelle à côté du fichier, valeurs par défaut `_defaults.json`, sous-dossier = code de rubrique ; délai de stabilité de 5 s (fichier en cours de copie ignoré) ; fichiers déplacés vers `_processed/` ou `_errors/` avec un `.error.txt`.
- **Messagerie** : ingestion IMAP des messages non lus ; objet → titre, expéditeur → auteur, date du message → date du document, adresse et objet en métadonnées dynamiques.

4. Tests (9 tests — `tests/test_sprint3_classement_import.py`)

Arborescence par défaut · classement automatique d'une facture (`FIN.01`) et d'un contrat de travail (`RH.01`) · priorité au classement manuel · suggestion pour un PV (`ADM.02`) · création, cycle refusé, suppression refusée/acceptée, droits · lot de 3 fichiers + 1 fichier vide en erreur · ZIP + manifeste avec rubriques explicite et automatique · dossier partagé (2 capturés, 1 rejeté avec cause) · e-mail avec pièce jointe PDF.

Résultat : 9/9 ✔️

5. Démonstration



Plan de classement

6. Rétrospective

- **Positif** : les services métier ne dépendant pas de FastAPI, le hot folder et l'ingestion e-mail réutilisent exactement la même logique que l'API (contrôles, audit, doublons).
- **Amélioration** : le score de classement est volontairement simple et explicable ; un apprentissage sur les documents déjà classés pourra l'enrichir.

Sprint 4 — Conversion PDF/A, OCR et moteur de recherche

Période : semaines 9 et 10 · **Exigences** : EX-02, EX-06, EX-09 **Vélocité** : 31 points engagés / 31 livrés

1. Objectif du sprint

Garantir la lisibilité à long terme (PDF/A), rendre les scans recherchables (OCR) et retrouver n'importe quel document en quelques secondes, par critères ou par son contenu.

2. Récits utilisateurs

ID	Récit	Points	Statut
US-4.1	En tant qu'archiviste, chaque document est converti en PDF/A en conservant l'original	8	✔️
US-4.2	En tant qu'utilisateur, je retrouve un scan par les mots qu'il contient (OCR)	8	✔️
US-4.3	En tant qu'utilisateur, je combine des critères (type, auteur, dates, rubrique, statut, métadonnée libre)	5	✔️
US-4.4	En tant qu'utilisateur, je cherche dans le texte intégral avec extrait surligné	5	✔️
US-4.5	En tant qu'utilisateur, les résultats sont triés par pertinence et paginés	3	✔️
US-4.6	En tant qu'exploitant, les conversions échouées sont relancées automatiquement	2	✔️

3. Réalisation

- **Chaîne de conversion** (`services/conversion.py`) exécutée en tâche de fond :

Format d'entrée	Outil	Résultat
PDF (natif ou scanné)	OCRmyPDF `--output-type pdfa-2 --skip-text`	PDF/A-2b + couche OCR si nécessaire
Image (PNG, JPEG, TIFF…)	OCRmyPDF (`--image-dpi 300`) ; à défaut Tesseract	PDF/A-2b recherchable
Bureautique (DOCX, ODT, XLSX, PPTX, RTF…)	LibreOffice headless, filtre PDF/A-2	PDF/A-2b
Texte	lecture directe + LibreOffice	PDF/A-2b

- L'original est **toujours conservé** ; la représentation PDF/A a sa propre empreinte SHA-256. Statuts : `DONE`, `PARTIAL` (texte extrait sans PDF/A), `FAILED`, `SKIPPED`, avec journal de conversion.
- **Recherche** (`services/search.py`) : 13 critères combinables, tri (pertinence, date, titre), pagination ; inclusion des sous-rubriques lors d'un filtre par rubrique ; documents éliminés exclus par défaut.

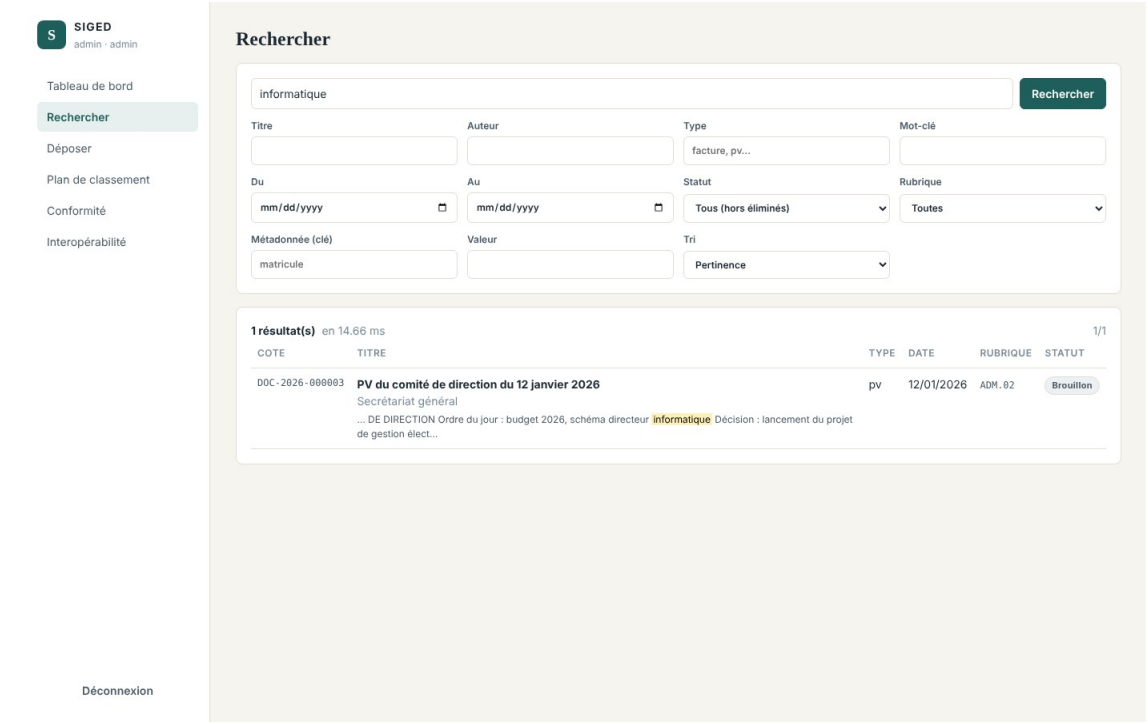
- **PostgreSQL** : `websearch_to_tsquery('french', …)` (syntaxe type moteur web : guillemets, `-exclusion`, `or`), index GIN, classement `ts_rank` + similarité trigramme du titre, extraits `ts_headline` surlignés. **SQLite** (développement) : repli `LIKE`.
- Chaque recherche avec critères est tracée (`SEARCH`).

4. Tests (9 tests — `tests/test_sprint4_conversion_recherche.py`)

Extraction du texte d'un PDF · recherche plein texte avec extrait surligné · combinaisons de critères (type, auteur, période, mot-clé accentué, tri) · filtre par rubrique incluant les sous-rubriques · métadonnée dynamique (matricule) · pagination · **conversion réelle PDF → PDF/A-2b · OCR réel d'une image → PDF/A-2b, puis retrouvée par son contenu · DOCX → PDF/A-2b via LibreOffice**, retrouvé par un mot accentué.

Résultat : 9/9 ✔️ (les 3 tests de conversion utilisent les vrais outils OCRmyPDF, Tesseract, Ghostscript, LibreOffice)

5. Démonstration



Recherche plein texte

6. Rétrospective

- **Difficulté** : sans Ghostscript, OCRmyPDF ne produit ni PDF/A ni PDF ; la chaîne bascule alors sur Tesseract et marque la version `PARTIAL`. Ghostscript et les données OCR françaises sont inclus dans l'image Docker.
- **Difficulté** : les mots-clés stockés en JSON étaient échappés (`é`) et la recherche de « réunion » échouait sous SQLite ; corrigé en sérialisant le JSON sans échappement ASCII.

- **Mesure** : sur 2 000 notices, recherche plein texte en 0,44 s sous PostgreSQL (objectif < 2 s tenu).

Sprint 5 — Prévisualisation, versions et circuit de validation

Période : semaines 11 et 12 · **Exigences** : EX-10, EX-11, EX-12 **Vélocité** : 28 points engagés / 28 livrés

1. Objectif du sprint

Consulter un document sans le télécharger, suivre ses révisions sans perdre l'historique et le faire approuver selon un circuit contrôlé.

2. Récits utilisateurs

ID	Récit	Points	Statut
US-5.1	En tant qu'utilisateur, je visualise le document dans le navigateur, y compris sur mobile	5	✔️
US-5.2	En tant que contributeur, je dépose une nouvelle version mineure (1.1) ou majeure (2.0)	5	✔️
US-5.3	En tant qu'utilisateur, je consulte et télécharge n'importe quelle version antérieure	2	✔️
US-5.4	En tant que contributeur, je soumets mon document à validation	3	✔️
US-5.5	En tant que valideur, j'approuve ou je rejette avec un motif	5	✔️
US-5.6	En tant que responsable qualité, un document validé est figé	3	✔️
US-5.7	En tant que SIRH, je suis notifié par webhook quand un document est validé	5	✔️

3. Réalisation

- **Aperçu** : les pages sont rendues côté serveur en images PNG (`/preview/pages`, `/preview/page/{n}`) à partir du PDF/A. Cette approche fonctionne sur tous les navigateurs, y compris Chrome Android qui n'affiche pas les PDF intégrés. Un bouton « Ouvrir le PDF » propose le flux PDF inline (`Content-Disposition: inline`, `no-store`).
- **Versions** : numérotation majeure/mineure, une seule version courante, historique jamais écrasé (contrainte d'unicité `(document, majeure, mineure)`), dépôt identique à la version courante refusé.
- **Machine à états** : `DRAFT → PENDING_VALIDATION → VALIDATED`, rejet vers `DRAFT` avec motif obligatoire ; transitions invalides → 409 ; historique dans `workflow_events`.
- **Règles de gestion** :

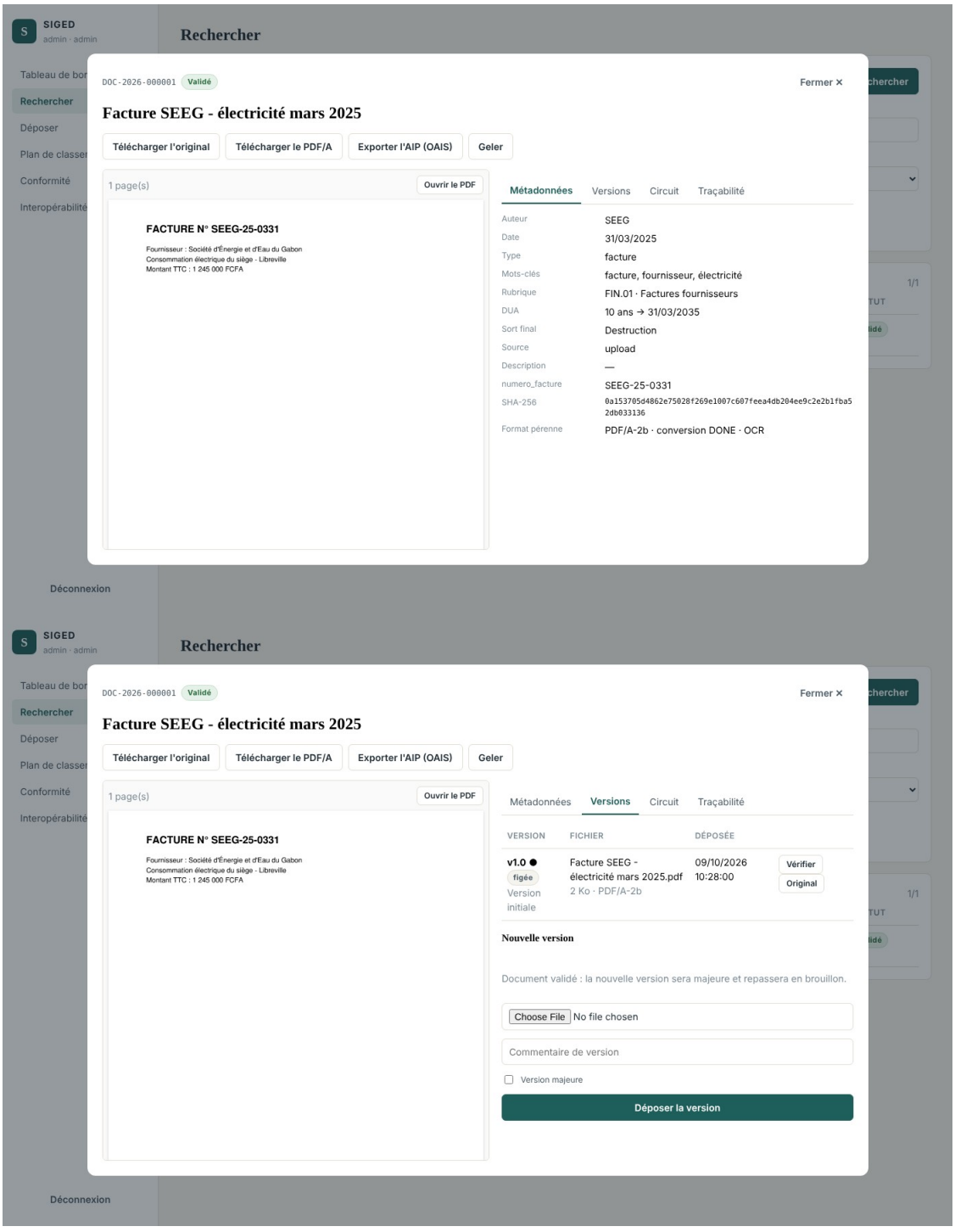
  - séparation des tâches : l'auteur ne peut pas valider son propre document (sauf administrateur) ;
  - aucune nouvelle version pendant la validation ;
  - un document validé a ses métadonnées figées ; une nouvelle version force la version majeure suivante et le repasse en brouillon, la version validée restant figée et consultable.
- **Notifications** : webhooks signés HMAC-SHA256 ; e-mail aux valideurs lors d'une soumission et à l'auteur lors d'une décision (si SMTP configuré).

4. Tests (11 tests — `tests/test_sprint5_versions_workflow.py`)

Aperçu inline identique à l'original déchiffré · aperçu en images PNG (page inexistante → 404) · téléchargement de l'original · versions 1.0 → 1.1 → 2.0 avec historique intact et v1.0 retéléchargeable à l'octet près · version identique refusée · circuit complet (soumission, tentative d'approbation sans droit, version interdite pendant la validation, rejet sans motif refusé, rejet, re-soumission, approbation, historique) · document validé figé puis réouvert en v2.0 · validateur sans droit d'écriture · auto-validation refusée · modification tracée avec ancienne et nouvelle valeur · webhook émis avec signature HMAC vérifiée.

Résultat : 11/11 ✔️

5. Démonstration


SIGED
admin · admin
Rechercher
Tableau de bor
Rechercher
Déposer
Plan de classer
Conformité
Interopérabilité
Déconnexion
DOC-2026-000001
Validé
Fermer ×
Facture SEEG - électricité mars 2025
Télécharger l'original
Télécharger le PDF/A
Exporter l'AIP (OAIS)
Geler
1 page(s)
Ouvrir le PDF
FACTURE N° SEEG-25-0331
Fournisseur : Société d'Énergie et d'Eau du Gabon
Consommation électrique du siège - Libreville
Montant TTC : 1 245 000 FCFA
Métadonnées
Versions
Circuit
Traçabilité
Auteur
SEEG
Date
31/03/2025
Type
facture
Mots-clés
facture, fournisseur, électricité
Rubrique
FIN.01 · Factures fournisseurs
DUA
10 ans → 31/03/2035
Sort final
Destruction
Source
upload
Description
—
numero_facture
SEEG-25-0331
SHA-256
0a153705d4862e75028f269e1007c607feea4db204ee9c2e2b1fba52db033136
Format pérenne
PDF/A-2b · conversion DONE · OCR

SIGED
admin · admin
Rechercher
Tableau de bor
Rechercher
Déposer
Plan de classer
Conformité
Interopérabilité
Déconnexion
DOC-2026-000001
Validé
Fermer ×
Facture SEEG - électricité mars 2025
Télécharger l'original
Télécharger le PDF/A
Exporter l'AIP (OAIS)
Geler
1 page(s)
Ouvrir le PDF
FACTURE N° SEEG-25-0331
Fournisseur : Société d'Énergie et d'Eau du Gabon
Consommation électrique du siège - Libreville
Montant TTC : 1 245 000 FCFA
Métadonnées
Versions
Circuit
Traçabilité
VERSION
FICHIER
DÉPOSÉE
v1.0
figée
Version initiale
Facture SEEG - électricité mars 2025.pdf
2 Ko · PDF/A-2b
09/10/2026 10:28:00
Vérifier
Original
Nouvelle version
Document validé : la nouvelle version sera majeure et repassera en brouillon.
Choose File
No file chosen
Commentaire de version
Version majeure
Déposer la version

ID	Récit	Points	Statut
US-6.4	En tant qu'archiviste, j'obtiens le bordereau des DUA échues et j'applique le sort final	8	✔️
US-6.5	En tant que juriste, je gèle un document en contentieux pour empêcher son élimination	2	✔️
US-6.6	En tant qu'archiviste, j'exporte un paquet d'archives OAIS (AIP)	5	✔️
US-6.7	En tant qu'administrateur, je supprime un brouillon déposé par erreur, avec motif	1	✔️

3. Réalisation

- **Journal chaîné** : `entry_hash = SHA-256(prev_hash, horodatage, acteur, action, objet, détails)` ; `GET /api/audit/verify` recalcule la chaîne et indique la première entrée rompue.
- **Inaltérabilité PostgreSQL** : déclencheurs bloquant `UPDATE`, `DELETE`, `TRUNCATE` sur `audit_logs`.
- **Écritures concurrentes** : verrou consultatif transactionnel `pg_advisory_xact_lock` (PostgreSQL) ou verrou de processus maintenu jusqu'à la fin de la transaction (SQLite) — voir rétrospective.
- **Actions tracées** : création, consultation de fiche, aperçu, téléchargement, recherche, modification (avant/après), versions, transitions de workflow, gel, export AIP, élimination, versement, contrôle d'intégrité, administration des comptes, clés et webhooks.
- **Contrôle d'intégrité** : relecture et déchiffrement de chaque objet (original et PDF/A), comparaison des empreintes ; anomalies enregistrées (`integrity_checks`), tracées (`INTEGRITY_FAILURE`) et notifiées (webhook `integrity.failure`) ; vérification unitaire par version.
- **DUA** : `retention_until` stocké et indexé ; bordereau (`/retention/due`), échéancier (`/retention/upcoming`), exécution simulée ou réelle (`/retention/run`) ; élimination physique avec certificat (empreintes détruites) ; versement définitif ; gel juridique.
- **AIP OAIS** : ZIP au format BagIt (manifeste SHA-256, toutes les versions, `description.json`, `pdi.json` avec provenance issue du journal).

4. Tests (13 tests — `tests/test_sprint6_conformite.py`)

Chaîne valide · altération d'une ligne détectée à l'entrée exacte (SQLite) · `UPDATE/DELETE` refusés par PostgreSQL · consultation, aperçu et téléchargement tracés · altération d'un octet d'un fichier stocké détectée par le contrôle global et par la vérification unitaire · bordereau (seuls les documents validés échus) et simulation sans effet · élimination : fichiers physiquement supprimés, notice et trace conservées, exclusion de la recherche · versement définitif puis modification refusée · gel excluant du bordereau · DUA au 29 février · AIP : contenu, manifeste vérifié fichier par fichier, provenance · suppression limitée aux brouillons, motif obligatoire · **80 écritures d'audit concurrentes sans rupture de chaîne**.

Résultat : 12 ✔️ + 1 test propre à l'autre SGBD ignoré par exécution (le test d'altération directe s'exécute sous SQLite, le test des déclencheurs sous PostgreSQL ; les deux sont verts dans la CI).

5. Démonstration

Conformité & traçabilité

Journal d'audit

Chaîne d'empreintes SHA-256 : toute altération est détectée.

Vérifier la chaîne

Chaîne d'audit rompue à l'entrée #27 (altération détectée) — 26 entrées vérifiées

Intégrité des fichiers

Recalcul des empreintes SHA-256 de tous les fichiers stockés.

Lancer le contrôle

12 fichiers contrôlés le 09/10/2026 11:30:00 : **0 anomalie(s)**

DUA échues — bordereau

Simuler | Appliquer le sort final

COTE	TITRE	TYPE	DATE	RUBRIQUE	STATUT
DOC-2026-000005	**Courrier au Ministère de l'Économie (2014)** Direction générale	courrier	20/05/2014	ADM.01	Validé
DOC-2026-000006	**Convention de partenariat ARTF (2003)** Direction juridique	convention	10/02/2003	JUR.01	Validé

Dernières entrées du journal

DATE	ACTEUR	ACTION	OBJET	IP
09/10/2026 10:29:56	admin	DOCUMENT_VIEW	document f87a1d3c-32e7-4c1c-8309-081b75e4b09f	127.0.0.1
09/10/2026 10:29:55	admin	DOCUMENT_VIEW	document f87a1d3c-32e7-4c1c-8309-081b75e4b09f	127.0.0.1
09/10/2026 10:29:54	admin	DOCUMENT_VIEW	document f87a1d3c-32e7-4c1c-8309-081b75e4b09f	127.0.0.1
09/10/2026 10:29:53	admin	DOCUMENT_PREVIEW	document f87a1d3c-32e7-4c1c-8309-081b75e4b09f	127.0.0.1
09/10/2026 10:29:53	admin	DOCUMENT_VIEW	document f87a1d3c-32e7-4c1c-8309-081b75e4b09f	127.0.0.1
09/10/2026 10:29:52	admin	SEARCH	search	127.0.0.1
09/10/2026 10:29:51	admin	SEARCH	search	127.0.0.1
09/10/2026 10:29:50	admin	LOGIN	user 1	127.0.0.1
09/10/2026 10:28:30	admin	INTEGRITY_CHECK	system 1	127.0.0.1
09/10/2026 10:28:29	admin	AUDIT_VERIFY	audit	127.0.0.1
09/10/2026 10:28:26	admin	DOCUMENT_PREVIEW	document ae34f948-81f3-4089-a8d3-603afafe2cb8	127.0.0.1
09/10/2026 10:28:25	admin	DOCUMENT_VIEW	document ae34f948-81f3-4089-a8d3-603afafe2cb8	127.0.0.1
09/10/2026 10:28:24	admin	DOCUMENT_PREVIEW	document ae34f948-81f3-4089-a8d3-603afafe2cb8	127.0.0.1
09/10/2026 10:28:24	admin	DOCUMENT_VIEW	document ae34f948-81f3-4089-a8d3-603afafe2cb8	127.0.0.1
09/10/2026 10:28:21	admin	DOCUMENT_PREVIEW	document ae34f948-81f3-4089-a8d3-603afafe2cb8	127.0.0.1
09/10/2026 10:28:21	admin	DOCUMENT_VIEW	document ae34f948-81f3-4089-a8d3-603afafe2cb8	127.0.0.1
09/10/2026 10:28:20	admin	SEARCH	search	127.0.0.1
09/10/2026 10:28:19	admin	LOGIN	user 1	127.0.0.1
09/10/2026 10:28:02	system	DOCUMENT_PROCESSED	document d68e9db4-5d8d-4fc0-ba50-5ec335c89a0e	
09/10/2026 10:28:02	system	DOCUMENT_PROCESSED	document ae34f948-81f3-4089-a8d3-603afafe2cb8	
09/10/2026 10:28:02	system	DOCUMENT_PROCESSED	document 48f8607e-ba0d-4937-a13a-dd0b2efba757	
09/10/2026 10:28:02	system	DOCUMENT_PROCESSED	document f87a1d3c-32e7-4c1c-8309-081b75e4b09f	
09/10/2026 10:28:02	system	DOCUMENT_PROCESSED	document bb562882-36de-4cfb-b398-c41fcf7a1327	
09/10/2026 10:28:02	system	DOCUMENT_PROCESSED	document 27d85b54-7d28-4e60-bf84-5a76c1362d7c	
09/10/2026 10:28:00	valideur	WORKFLOW_APPROVE	document d68e9db4-5d8d-4fc0-ba50-5ec335c89a0e	127.0.0.1
09/10/2026 10:28:00	redacteur	WORKFLOW_SUBMIT	document d68e9db4-5d8d-4fc0-ba50-5ec335c89a0e	127.0.0.1
09/10/2026 10:28:00	redacteur	DOCUMENT_CREATE	document d68e9db4-5d8d-4fc0-ba50-5ec335c89a0e	127.0.0.1
09/10/2026 10:28:00	valideur	WORKFLOW_APPROVE	document 27d85b54-7d28-4e60-bf84-5a76c1362d7c	127.0.0.1
09/10/2026 10:28:00	redacteur	WORKFLOW_SUBMIT	document 27d85b54-7d28-4e60-bf84-5a76c1362d7c	127.0.0.1
09/10/2026 10:28:00	redacteur	DOCUMENT_CREATE	document 27d85b54-7d28-4e60-bf84-5a76c1362d7c	127.0.0.1
09/10/2026 10:28:00	redacteur	WORKFLOW_SUBMIT	document bb562882-36de-4cfb-b398-c41fcf7a1327	127.0.0.1
09/10/2026 10:28:00	redacteur	DOCUMENT_CREATE	document bb562882-36de-4cfb-b398-c41fcf7a1327	127.0.0.1
09/10/2026 10:28:00	redacteur	DOCUMENT_CREATE	document ae34f948-81f3-4089-a8d3-603afafe2cb8	127.0.0.1
09/10/2026 10:28:00	valideur	WORKFLOW_APPROVE	document 48f8607e-ba0d-4937-a13a-dd0b2efba757	127.0.0.1
09/10/2026 10:28:00	redacteur	WORKFLOW_SUBMIT	document 48f8607e-ba0d-4937-a13a-dd0b2efba757	127.0.0.1

6. Rétrospective

- **Anomalie trouvée en démonstration** : la vérification du journal a signalé une rupture. Cause : plusieurs conversions en tâche de fond écrivaient en même temps et lisaient la même « dernière empreinte », ce qui créait une bifurcation de la chaîne. Correction : sérialisation des écritures jusqu'à la fin de la transaction, et test de non-régression avec 8 fils et 80 écritures. Cet incident montre l'intérêt du chaînage : une incohérence invisible autrement a été détectée immédiatement.
- **Difficulté** : le script SQL PostgreSQL contient des % (PL/pgSQL) interprétés comme paramètres par le pilote ; exécution directe sur la connexion brute.

Sprint 7 — Interopérabilité, interface web, performance et recette

Période : semaines 15 et 16 · **Exigences** : EX-04, EX-16 (transit), EX-20, recette globale
Vélocité : 30 points engagés / 30 livrés

1. Objectif du sprint

Livrer une application utilisable de bout en bout, connectable au système d'information, mesurée et déployable.

2. Récits utilisateurs

ID	Récit	Points	Statut
US-7.1	En tant qu'utilisateur, je dispose d'une interface web complète, utilisable sur mobile	8	✔
US-7.2	En tant qu'administrateur, je gère clés d'API et webhooks depuis l'interface	3	✔
US-7.3	En tant que DSI, je dispose d'un contrat d'API OpenAPI	1	✔
US-7.4	En tant qu'exploitant, je déploie toute la solution en une commande, en TLS 1.3	5	✔
US-7.5	En tant qu'exploitant, je supervise la santé et les temps de réponse	3	✔
US-7.6	En tant qu'exploitant, les sauvegardes sont quotidiennes et restaurables	5	✔
US-7.7	En tant que chef de projet, je vérifie la tenue des 2 s sur un volume représentatif	3	✔
US-7.8	En tant que formateur, je dispose d'un jeu de données de démonstration	2	✔

3. Réalisation

- **Interface web** (JavaScript natif, sans dépendance externe, adaptée au mobile) : tableau de bord, recherche multicritère avec extraits surlignés, dépôt unitaire ou par lot, fiche document (aperçu, métadonnées, versions, circuit, traçabilité), plan de classement,

conformité (vérification du journal, intégrité, bordereau DUA), interopérabilité. Les menus et actions dépendent des permissions ; tout contenu est échappé (protection XSS).

- **Déploiement** : `docker-compose.yml` (Caddy, API, worker, PostgreSQL, volume de stockage chiffré, sauvegarde) ; image incluant Tesseract (fra/eng), Ghostscript, LibreOffice ; utilisateur non root ; sonde de santé.
- **TLS 1.3** exclusif, HSTS, CSP ; certificat Let's Encrypt obtenu et renouvelé automatiquement par Caddy (certificat local auto-signé pour les tests sur poste).
- **Hébergement** : VM gratuite Oracle Cloud Always Free (ARM64), scripts `deploy/oracle/` d'installation, de démarrage et de mise à jour.
- **Supervision** : `/health` (base + stockage, 503 si dégradé), en-tête `X-Process-Time-ms` sur chaque réponse, journalisation des requêtes de plus de 2 s, indicateurs `/api/admin/stats`.
- **Sauvegardes** : dump PostgreSQL + objets chiffrés chaque nuit, `SHA256SUMS`, rétention 30 jours, script de restauration avec vérification.
- **CI** : GitHub Actions exécute toute la suite sur SQLite et PostgreSQL avec les vrais outils OCR.
- **Jeu de démonstration** : `python -m scripts.demo_data` crée 4 comptes (un par rôle) et 6 documents réalistes à différents stades.

4. Tests (7 tests — `tests/test_sprint7_perf_interop.py`) et mesures

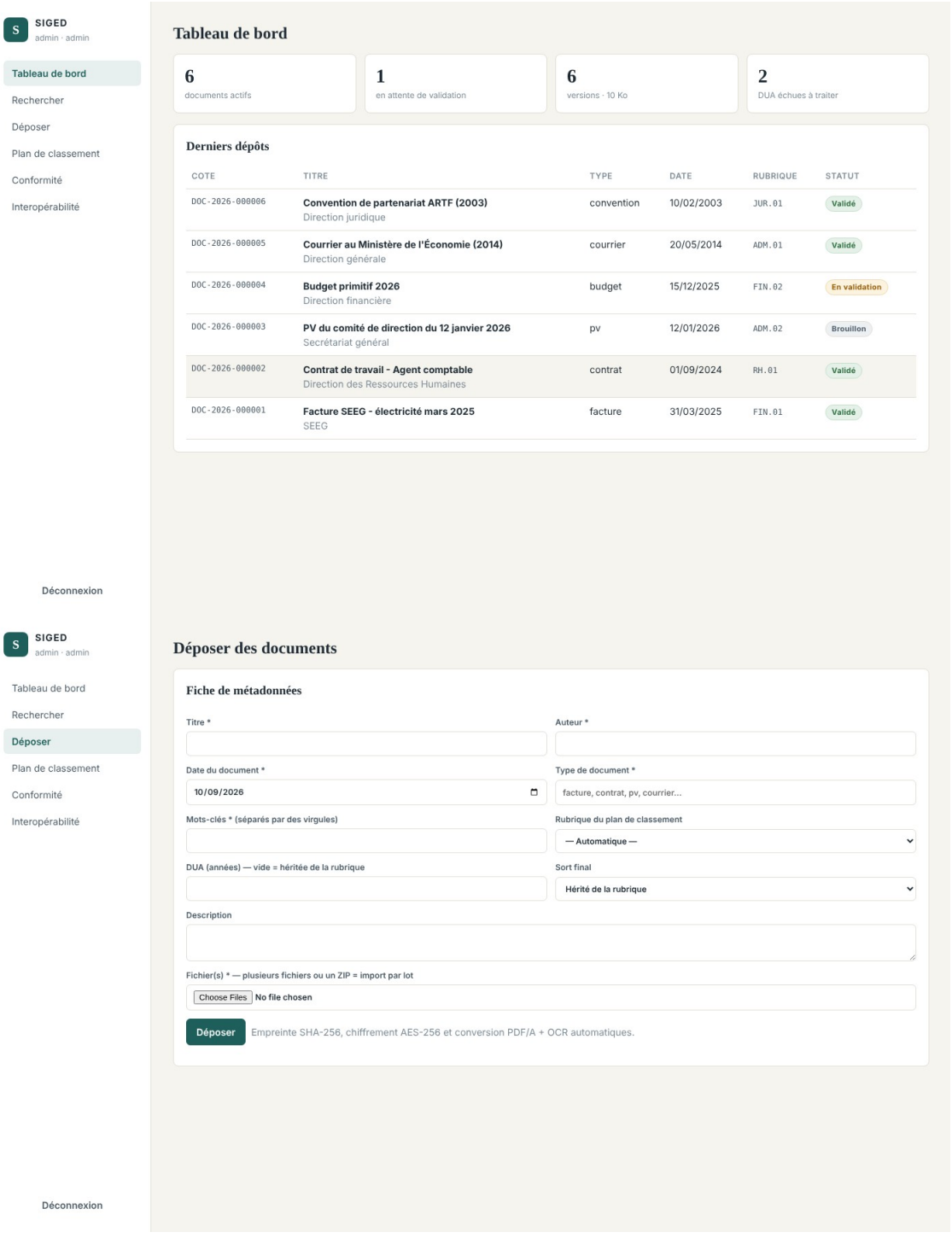
Sonde de santé · en-têtes de performance et de sécurité · interface servie · contrat OpenAPI exposant les routes clés · indicateurs du tableau de bord · **test de charge : 2 000 notices, 4 types de recherche < 2 s · démarrage simultané de 6 processus sans conflit d'initialisation**.

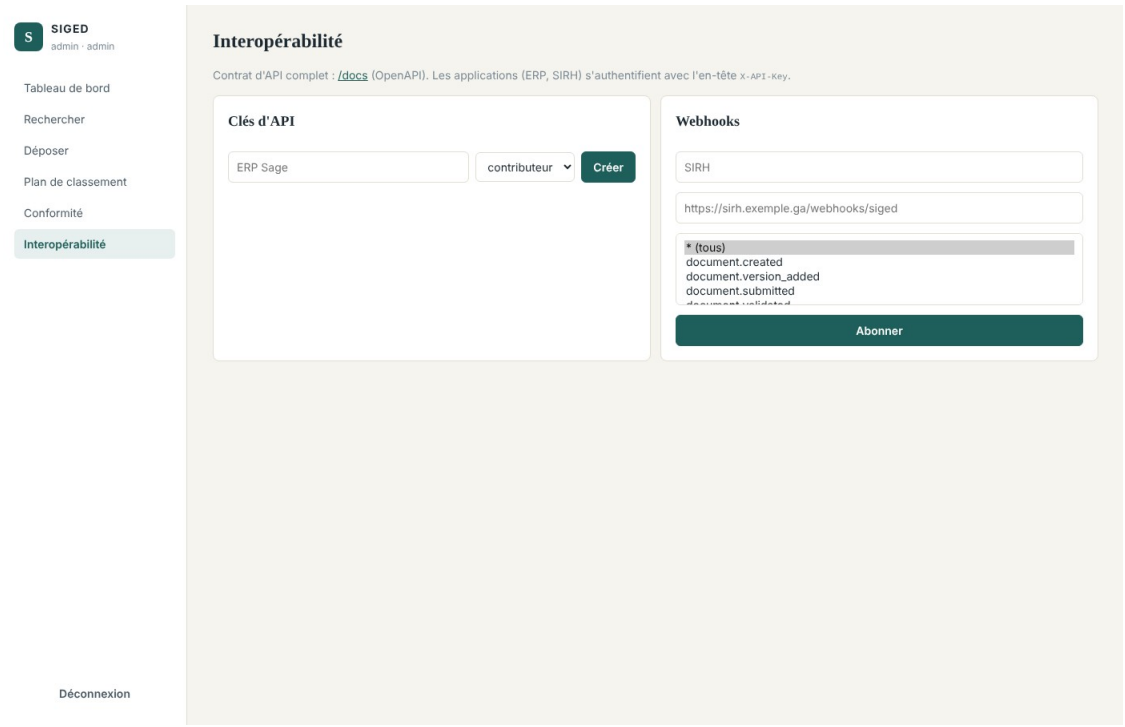
Recherche (2 000 notices)	SQLite	PostgreSQL 16
Plein texte « convention » (200 résultats)	66 ms	442 ms
Type + date	13 ms	17 ms
Auteur + tri	23 ms	41 ms
Liste sans critère	23 ms	33 ms

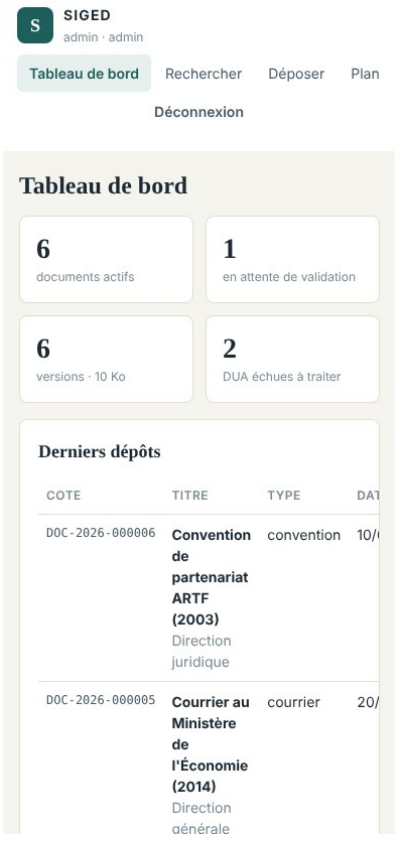
PostgreSQL est plus lent en plein texte car il calcule la racinisation, le classement et les extraits surlignés que SQLite ne fait pas ; il reste 4,5 fois sous l'objectif.

Résultat : 7/7 ✔️

5. Démonstration







6. Rétrospective

- **Positif** : la recette sur données réalistes a révélé trois défauts corrigés avant livraison : bifurcation du journal sous concurrence, aperçu PDF non universel, et création

concurrente du schéma par les workers Uvicorn au démarrage (corrigée par un verrou consultatif PostgreSQL, testé avec plusieurs processus).

- **Dette technique identifiée** : migrations Alembic, cache des aperçus, colonne `tsvector` stockée pour accélérer le classement plein texte, test de charge en conditions de production (plusieurs centaines de milliers de documents).

Rapport final — Bilan du projet et recette

1. Synthèse

SIGED couvre les **20 exigences** du cahier des charges. Le projet a été conduit en 8 sprints (cadrage + 7 sprints de réalisation) pour **199 points** livrés sur 199 engagés.

Indicateur	Valeur
Code applicatif Python	≈ 3 500 lignes (hors tests)
Interface web	3 fichiers (HTML, CSS, JavaScript natif)
Opérations d'API documentées (OpenAPI)	48
Tables	11
Tests automatisés	78 (SQLite : 76 réussis, 2 propres à PostgreSQL ignorés ; PostgreSQL : 77 réussis, 1 propre à SQLite ignoré)
Recherche plein texte sur 2 000 notices	0,44 s (PostgreSQL) — objectif < 2 s

2. Matrice de conformité

Réf.	Exigence	Réalisation	Preuve (tests)	Statut
EX-01	Centralisation, pas de doublons	Référentiel unique, refus des doublons par empreinte	`test_duplicate_detection`	✔️
EX-02	Recherche par métadonnées	13 critères, index B-tree / trigrammes	`test_metadata_criteria`, `test_search_dynamic_metadata`	✔️
EX-03	Sécurité et traçabilité	JWT, RBAC, journal chaîné	sprints 1 et 6	✔️
EX-04	Interopérabilité ERP/SIRH/messagerie	API + clés, webhooks HMAC, IMAP, SMTP, OpenAPI	`test_api_key_for_erp`, `test_webhooks_signed`, `test_mail_ingestion`, `test_openapi_contract`	✔️
EX-	Manuel, lot,	Dépôt, lot/ZIP +	`test_batch_*`,	✔️

Réf.	Exigence	Réalisation	Preuve (tests)	Statut
05	capture auto	manifeste, dossier partagé, API	`test_hot_folder_capture`	
EX-06	PDF/A + OCR	OCRmyPDF, Tesseract, LibreOffice → PDF/A-2b	`test_pdf_converted_to_pdfa`, `test_scanned_image_ocr_is_searchable`, `test_docx_converted_to_pdfa`	✔️
EX-07	Fiche de métadonnées obligatoire	Validation stricte, héritage DUA de la rubrique	`test_mandatory_metadata`, `test_dua_*`	✔️
EX-08	Plan de classement, auto/manuel	Arborescence + règles explicables	`test_auto_classification_on_upload`, `test_manual_classification_wins`	✔️
EX-09	Recherche multicritère + plein texte	FTS français, extraits surlignés	`test_fulltext_search_finds_content`	✔️
EX-10	Prévisualisation sans téléchargement	Pages rendues en PNG + PDF inline	`test_preview_inline_without_download`, `test_preview_as_page_images`	✔️
EX-11	Versions sans écraser l'historique	Majeure/mineure, historique immuable	`test_minor_and_major_versions_keep_history`	✔️
EX-12	Workflow brouillon/validation/validé	Machine à états, séparation des tâches	`test_full_workflow`, `test_author_cannot_self_validate`	✔️
EX-13	Stockage hybride	PostgreSQL + volume de fichiers chiffrés (ou stockage objet S3)	`test_metadata_stored_separately_from_file`	✔️
EX-14	SHA-256 au dépôt, non-altération	Empreinte en flux + contrôle nocturne	`test_upload_creates_document_v1`, `test_integrity_check_detects_tampering`	✔️
EX-15	RBAC	5 rôles, 10 permissions	`test_rbac_*`	✔️
EX-16	TLS 1.3 + AES-256	Caddy TLS 1.3 uniquement (Let's	`test_files_are_encrypted_at_rest`,	✔️

Réf.	Exigence	Réalisation	Preuve (tests)	Statut
		Encrypt automatique) ; AES-256-GCM applicatif	`test_crypto_roundtrip_and_tamper_detection` ; configuration `deploy/caddy/Caddyfile`	
EX-17	ISO 15489 / ISO 14721	Correspondances détaillées (cahier §9), export AIP BagIt	`test_aip_export_oais`	✔️
EX-18	DUA et sort final automatisés	Job quotidien, bordereau, élimination certifiée, versement, gel	`test_retention_*`, `test_legal_hold_blocks_disposal`	✔️
EX-19	Journal d'audit inaltérable	Chaîne SHA-256 + déclencheurs PostgreSQL	`test_audit_*`, `test_consultations_are_traced`	✔️
EX-20	< 2 s, 99,9 %, sauvegardes	Mesures automatisées ; architecture HA décrite ; sauvegarde quotidienne	`test_search_under_two_seconds_on_volume`, `test_health`	✔️ (HA : architecture cible, voir §4)

3. Scénario de recette de bout en bout

1. L'administrateur crée les comptes `redacteur` (contributeur) et `valideur` (validateur).
2. Le rédacteur dépose une facture scannée (image) : cote attribuée, empreinte affichée, rubrique `FIN.01` attribuée automatiquement, DUA de 10 ans héritée.
3. Quelques secondes plus tard, la version est convertie en PDF/A-2b avec OCR ; la recherche « SEEG » la retrouve avec un extrait surligné.
4. Le rédacteur la soumet ; le valideur la rejette (« montant erroné ») ; le rédacteur dépose la v1.1 corrigée et la resoumet ; le valideur l'approuve : version figée, webhook envoyé au SIRH/ERP.
5. Un auditeur vérifie le journal (chaîne intègre) et lance un contrôle d'intégrité (0 anomalie).
6. Simulation d'altération d'un fichier sur le stockage → le contrôle signale l'anomalie et une alerte est émise.
7. À échéance de la DUA, l'archiviste consulte le bordereau, applique le sort final ; la facture est éliminée, sa notice et le certificat d'élimination restent consultables.

Le jeu de démonstration (`scripts/demo_data.py`) permet de rejouer ce scénario en quelques minutes.

4. Réserves et suite à donner

Réserve	Nature	Proposition
Disponibilité 99,9 %	La composition livrée est mono-serveur ; l'objectif suppose la redondance	Déployer l'architecture cible (2 API, PostgreSQL répliqué avec bascule, MinIO distribué) décrite au cahier §10.2
Volumétrie	Tests de charge réalisés sur 2 000 notices	Campagne sur un volume de production (≥ 100 000 documents) avant mise en service
Valeur probante renforcée	Horodatage interne	Horodatage qualifié RFC 3161 des empreintes
Annuaire	Comptes locaux	Connexion LDAP / Active Directory ou OpenID Connect
Migrations de schéma	`create_all`	Alembic avant la première mise à jour en production

5. Bilan personnel

Le projet a mobilisé la conception de systèmes d'information (modélisation, architecture en couches), la sécurité (cryptographie appliquée, contrôle d'accès, analyse de menaces), l'administration de bases de données (index plein texte, déclencheurs, sauvegarde/restauration) et l'administration système (conteneurs, TLS, supervision). Les défauts découverts en recette — bifurcation du journal sous concurrence, aperçu PDF non universel, initialisation concurrente du schéma au démarrage — rappellent que les exigences non fonctionnelles se valident par des essais réalistes et non sur le papier.